

CVSS 4.0: Indicadores, Métricas y Aplicación Territorial en España

Marco de Referencia, Tendencias 2025–2026 y Perspectiva Comparativa Mundial

"Una puntuación de diez que lo dice todo no dice nada. Una puntuación de siete con contexto lo dice todo lo que importa."

— Sentencia del campo, endosada implícitamente por el FIRST CVSS SIG

Resumen Ejecutivo

El Common Vulnerability Scoring System en su versión 4.0 (CVSS 4.0), publicado oficialmente el 1 de noviembre de 2023 por el Forum of Incident Response and Security Teams (FIRST), representa la transformación más profunda del estándar desde su creación en 2005. Abandonando el modelo tripartito clásico —Base, Temporal, Environmental— en favor de una arquitectura cuadripartita que incorpora los grupos **Threat** y **Supplemental**, la nueva versión aspira a superar la crítica más persistente que ha perseguido al sistema: la tendencia a confundir severidad técnica con riesgo operacional real.^{[1][2][3]}

En el contexto español, el CVSS 4.0 cobra una dimensión territorial precisa: INCIBE-CERT lo ha adoptado como métrica primaria de clasificación de gravedad en sus alertas de vulnerabilidades, mientras que el CCN-CERT opera la Red Nacional de SOC —con más de 250 centros interconectados— donde las métricas de vulnerabilidad e indicadores CVSS circulan como inteligencia compartida entre administraciones autonómicas, locales y la Administración General del Estado. El año 2025 ha sido, además, el más intenso registrado en incidentes: INCIBE gestionó 122.223 ciberincidentes (+26% interanual) y detectó 237.028 sistemas vulnerables en territorio español.^{[4][5][6][7][8][9]}

1. Genealogía y Arquitectura de CVSS 4.0

1.1 De la Necesidad a la Norma

El CVSS nació en 2005 como proyecto del US National Infrastructure Advisory Council (NIAC), con la ambición de crear un lenguaje común para describir la severidad de las vulnerabilidades de software. Su custodia pasó al FIRST, organización global que coordina el CVSS Special Interest Group (CVSS-SIG), colectivo de profesionales de ciberseguridad que ha moldeado cada versión mediante investigación, pruebas y refinamiento continuo.^[10]

Tras dos décadas de evolución —CVSSv1 (2005), CVSSv2 (2007), CVSSv3.0 (2015), CVSSv3.1 (2019)— la versión 4.0 fue anunciada públicamente en julio de 2023 y lanzada de forma oficial en noviembre de ese mismo año. El salto entre CVSSv3.1 y 4.0 no fue meramente cosmético: el SIG trabajó durante años en el redesign, procesando **15 millones de vectores CVSS-BTE** a través de 270 conjuntos de equivalencia (*equivalence sets*), los cuales fueron ordenados por expertos mediante técnicas de comparación pareada y *agglomerative hierarchical clustering*. El resultado es un sistema de puntuación cuya matemática interna es explícitamente no lineal, algo que sus predecesores jamás reconocieron de forma tan transparente.^{[11][12][1]}

1.2 La Arquitectura Cuadripartita

CVSS 4.0 se estructura en cuatro grupos de métricas que responden a preguntas complementarias sobre la naturaleza de una vulnerabilidad:[²][¹³]

Grupo	Propósito	Quién lo establece	Impacto en puntuación
Base	Características intrínsecas, invariantes en el tiempo	Proveedor / PSIRT	Siempre (núcleo)
Threat	Madurez del exploit y actividad observada	Consumidor / CTI	Sí (ajuste)
Environmental	Contexto de despliegue y controles mitigadores	Consumidor / analista	Sí (ajuste)
Supplemental	Atributos extrínsecos adicionales	Consumidor / sector	No (contexto)

La nomenclatura de puntuación resultante es deliberadamente explícita sobre qué grupos se han incorporado:[¹⁴]

- **CVSS-B**: Solo métricas Base
- **CVSS-BT**: Base + Threat
- **CVSS-BE**: Base + Environmental
- **CVSS-BTE**: Base + Threat + Environmental (puntuación más completa)

Esta nomenclatura aspira a terminar con una de las patologías más extendidas del ecosistema de gestión de vulnerabilidades: la presentación del CVSS-B como si fuera la puntuación definitiva, cuando en realidad es solo el punto de partida del ciclo de vida.[¹⁵]

2. Métricas Base: Lo Que No Cambia

Las métricas Base capturan las características intrínsecas de la vulnerabilidad —aquellas que permanecen constantes independientemente del entorno de despliegue o del momento en el tiempo. CVSS 4.0 introduce modificaciones sustanciales respecto a CVSSv3.1.[¹⁶]

2.1 Métricas de Explotabilidad

Métrica	v3.1	v4.0	Cambio clave
Attack Vector (AV)	Network/Adjacent/ Local/Physical	Network/Adjacent/ Local/Physical	Sin cambio en valores
Attack Complexity (AC)	Low/High	Low/High	Scope reducido: solo complejidad del exploit
Attack Requirements (AT)	No existía	None/Present	Nueva: condiciones en el objetivo necesarias para explotar
Privileges Required (PR)	None/Low/High	None/Low/High	Definición refinada
User Interaction (UI)	None/Required	None/Passive/Active	Nuevos valores: distinción entre interacción pasiva y activa

La separación de **Attack Complexity (AC)** y el nuevo **Attack Requirements (AT)** resuelve una ambigüedad histórica del sistema. En v3.1, AC englobaba tanto la complejidad del exploit en sí como las condiciones ambientales del objetivo, mezclando categorías lógicamente distintas. En v4.0, AC se centra exclusivamente en la complejidad técnica del exploit (por ejemplo, necesidad de eludir ASLR o DEP), mientras que AT evalúa si la explotación requiere condiciones específicas en el componente objetivo que el atacante no puede controlar (por ejemplo, una configuración no predeterminada).^[17]^[18]

2.2 Métricas de Impacto: El Fin del Scope

El antiguo parámetro **Scope** de CVSSv3.x —que intentaba capturar si la explotación afectaba a sistemas más allá del componente vulnerable— ha sido eliminado y reemplazado por una distinción más nítida entre impacto en el **sistema vulnerable** y en los **sistemas subsecuentes**.^[19]^[1]

Las métricas de impacto ahora se organizan en dos conjuntos paralelos:

- VC/VI/VA (Vulnerable System Confidentiality/Integrity/Availability): impacto sobre el propio sistema comprometido
- SC/SI/SA (Subsequent System Confidentiality/Integrity/Availability): impacto en cascada sobre sistemas interconectados

Esta arquitectura resulta especialmente relevante para entornos OT/ICS/SCADA, donde la explotación de un nodo puede tener consecuencias físicas en sistemas de control industrial aguas abajo. Un ejemplo directo de la guía oficial FIRST: un equipo OT/ICS/SCADA conectado a una pasarela de red que puede verse afectado secundariamente por la explotación de otro componente queda ahora correctamente representado mediante SC/SI/SA.^[20]

3. Métricas Threat: La Inteligencia que Ajusta

3.1 El Cambio de Paradigma: De Temporal a Threat

El grupo **Temporal** de CVSSv3.x ha sido renombrado como **Threat** en v4.0, y no es solo una cuestión nominal. El cambio refleja una reorientación filosófica: mientras las métricas temporales enfatizaban atributos del ciclo de vida del parche (nivel de remediación, confianza en el reporte), las métricas Threat se centran en la **inteligencia sobre amenazas activas**.^{[^21][^22]}

El grupo Threat en v4.0 contiene una única métrica principal: **Exploit Maturity (E)**, cuyos valores anteriores "High" y "Functional" han sido consolidados en un único valor **"Attacked" (A)**, simplificando la escala:

Valor	Significado
Not Defined (X)	Valor por defecto; el sistema asume el peor escenario
Unreported (U)	Sin evidencia de exploit funcional ni prueba de concepto
Proof-of-Concept (P)	Existe PoC, pero no se ha reportado explotación activa
Attacked (A)	Explotación activa documentada (fusión de "High" y "Functional" de v3.x)

Las métricas **Remediation Level (RL)** y **Report Confidence (RC)** presentes en CVSSv3.1 han sido **eliminadas** en v4.0. La justificación es pragmática: en la práctica, estos campos rara vez se actualizaban y generaban ruido más que señal.^[^22]

3.2 El Impacto Numérico de Threat sobre la Priorización

El poder real de las métricas Threat sobre la gestión de vulnerabilidades se hace evidente en los datos empíricos comparativos entre v3.1 y v4.0. Tomando como base un corpus de ~8.000 vulnerabilidades:^[^11]

Para el umbral ≥ 7.0 :

- CVSSv3.1 (solo Base): 3.028 vulnerabilidades (38%)
- CVSSv3.1 (con Temporal): 1.775 vulnerabilidades → reducción del 40%
- CVSS v4.0 (solo Base): 3.288 vulnerabilidades (41.3%)
- CVSS v4.0 (con Threat): 1.177 vulnerabilidades → **reducción del 65%**

Para el umbral ≥ 8.0 :

- CVSSv3.1 (con Temporal): 818 vulnerabilidades → reducción del 43%
- CVSS v4.0 (con Threat): 631 vulnerabilidades → **reducción del 76%**

La diferencia no es trivial: donde CVSSv3.1 reducía la carga de trabajo en un 40-43% al incorporar inteligencia de amenazas, CVSS v4.0 lo hace en un 65-76%. El nuevo modelo matemático basado en *equivalence groups* produce una brecha sustancialmente mayor entre la puntuación Base y la

puntuación con Threat, lo que permite una **priorización mucho más discriminatoria** de las vulnerabilidades que realmente merecen atención urgente.^[^11]

La guía oficial de implementación para consumidores (Consumer Implementation Guide, publicada en enero de 2026) documenta que solo entre el 3% y el 5% de los CVEs tienen exploits conocidos, lo que significa que aplicar correctamente la métrica de Exploit Maturity puede transformar radicalmente la lista de prioridades.^[^15]

4. Métricas Environmental: El Contexto que Calibra

4.1 Métricas Base Modificadas (Modified Base Metrics)

Las métricas ambientales permiten al consumidor —el analista de seguridad que conoce su entorno de despliegue— ajustar las asunciones del proveedor para reflejar controles y mitigaciones existentes. La filosofía es clara: el proveedor asigna el peor escenario razonable; el consumidor lo calibra a su realidad.^[^15]

Las métricas modificadas siguen la nomenclatura **M + métrica base** (MAV, MAC, MAT, MPR, MUI, MVC, MVI, MVA, MSC, MSI, MSA) y permiten demostrar matemáticamente el valor de los controles de seguridad:

Control aplicado	Métrica modificada	Efecto ejemplo (puntuación 9.3)
Firewall perimetral	MAV: Network → Adjacent	9.3 → 8.7
IPS con firma validada	MAC: Low → High	9.3 → 7.7
Acceso solo desde consola	MAV: Network → Local	9.3 → 8.6
Restricción de privilegios	MPR: Low → High	9.3 → 7.3
Document sandboxing	MUI: Passive → Active	9.3 → 5.4
Cifrado datos en reposo + sin exploit	MVC: High → Low + E:U	9.3 → 0.7

La combinación de múltiples controles puede reducir una vulnerabilidad crítica (9.3) hasta niveles mínimos (0.1–1.0), siempre que los controles estén **validados y documentados**. Este efecto tiene implicaciones directas para el sector público español: una entidad que ha implementado correctamente las medidas ENS de categoría Alta puede argumentar, con métricas ambientales verificables, que su exposición real es muy inferior a la puntuación Base publicada.^[^15]

4.2 Requisitos de Seguridad (CR/IR/AR)

Las métricas de **Confidentiality Requirements (CR)**, **Integrity Requirements (IR)** y **Availability Requirements (AR)** permiten ponderar la importancia del activo afectado dentro de la misión de la organización. Un sistema de señalización digital en una cafetería tendrá CR: Low, IR: Low, AR: Low. Un sistema de historia clínica electrónica de un hospital tendrá CR: High, IR: High, AR: High. La misma vulnerabilidad base se convierte en dos prioridades radicalmente distintas.^[^15]

Para la Administración Pública española, este mecanismo se alinea naturalmente con la categorización ENS (BAJO/MEDIO/ALTO), donde la categoría del sistema determina el nivel de controles exigidos. Los sistemas de categoría ALTA (aquellos cuya perturbación causaría perjuicio grave o muy grave a intereses nacionales) justifican automáticamente CR/IR/AR: High, elevando la puntuación efectiva de las vulnerabilidades que los afectan.^[^23]^[^24]

5. Métricas Supplemental: El Contexto que No Puntúa (pero Importa)

Las métricas Supplemental constituyen la innovación más audaz —y más debatida— de CVSS 4.0. Estas métricas **no afectan la puntuación numérica** CVSS-BTE, pero proporcionan información contextual que puede ser decisiva para la toma de decisiones en sectores específicos.^[^14]^[^22]

Métrica	Valores	Aplicación principal
Safety (S)	Negligible / Present	Sistemas OT/ICS, dispositivos médicos, infraestructuras críticas
Automatability (AU)	No / Yes	Evaluación de amenazas autorreplicantes (gusanos)
Recovery (R)	Automatic / User / Irrecoverable	Resiliencia y continuidad de negocio
Value Density (VD)	Diffuse / Concentrated	Impacto del control sobre activos de alto valor
Vulnerability Response Effort (VRE)	Low / Moderate / High	Priorización de esfuerzo de respuesta
Provider Urgency (U)	Clear / Amber / Red / Critical	Canal de urgencia del fabricante

La métrica **Safety** es especialmente relevante para el contexto español: cuando se aplica a hospitales, centrales eléctricas, sistemas de control de tráfico aéreo o plantas de tratamiento de agua, el valor "Present" señala que la explotación podría causar daño físico a personas. Esta señalización no altera el número, pero obliga a los equipos de respuesta a considerar consecuencias que trascienden el dominio puramente informático.^[^25]^[^26]

La métrica **Automatability** responde a la pregunta: *¿puede un atacante automatizar la explotación de esta vulnerabilidad contra múltiples objetivos?* Si la respuesta es "Yes", el sistema CVSS indica que la vulnerabilidad es potencialmente **vermiforme** (wormable), capaz de propagarse a velocidad de máquina, reduciendo drásticamente el tiempo disponible entre la notificación pública del exploit y el ataque masivo.^[^27]

Un estudio académico publicado en *Health and Technology* (2025) aplicó CVSS BTE completo a dispositivos médicos, demostrando que la incorporación de métricas Threat y Environmental —especialmente Safety— transforma radicalmente la evaluación de riesgo en entornos sanitarios. La limitación identificada es elocuente: el CVSS-B de dispositivos médicos está disponible públicamente, pero las puntuaciones Threat y Environmental "rara vez se calculan y casi nunca se reportan".^[^28]

6. El Modelo Matemático: Equivalence Groups y No-Linealidad

Una de las contribuciones más significativas —y menos divulgadas— de CVSS 4.0 es la transparencia sobre su fundamento matemático. Mientras las versiones anteriores usaban fórmulas matemáticas que el SIG reconocía no tener "sólida fundamentación matemática", la v4.0 adopta un enfoque radicalmente distinto:[¹²][²⁸]

1. Los 15 millones de vectores CVSS-BTE posibles se agrupan en 270 conjuntos de equivalencia mediante clasificación por grupos de métricas
2. Expertos del SIG (voluntarios de organizaciones globales) comparan parejas de conjuntos y los ordenan por severidad relativa mediante técnicas de puntuación tipo Elo
3. Se aplica clustering jerárquico aglomerativo para asignar puntuaciones a cada conjunto garantizando que cualquier cambio en una métrica produce al menos un cambio de 0.1 en la puntuación
4. Un pequeño factor de ajuste garantiza que vectores dentro del mismo conjunto de equivalencia tengan puntuaciones ligeramente diferenciadas

El resultado es una escala con 101 valores posibles (0.0–10.0 en pasos de 0.1) pero cuya distribución interna es no lineal, lo que produce el efecto observado: scores CVSS 4.0 "tienden a recentrarse alrededor de Medium" en comparación con v3.x. Esto explica por qué el mismo CVE puede tener puntuaciones dramáticamente distintas según la versión: CVE-2021-22566 fue High (7.5) en v2.0, Critical (9.8) en v3.1, y Medium (5.1) en v4.0.[²⁹]

7. Estado de Adopción Global: El Abismo entre Norma y Práctica

7.1 Cifras de Adopción (2025)

La adopción de CVSS 4.0 en el ecosistema global revela una brecha significativa entre la norma técnica y su implementación práctica:[³⁰]

- Solo el 2,4% de los CVEs tenían puntuación CVSS v4 asignada en mayo de 2025, año y medio después del lanzamiento oficial
- Más del 50% de esos CVEs con v4 procedían de una única Autoridad de Numeración CVE (CNA), lo que sugiere que la adopción se concentra en un número muy limitado de actores
- El NVD contaba con un backlog de más de 26.815 CVEs sin analizar a finales de 2025[³¹]
- En 2025 se publicaron 48.185 CVEs totales (+20,6% respecto a 2024), lo que supone que el sistema de puntuación se enfrenta a una presión estructural sin precedentes[³²]
- La puntuación media CVSS en 2025 fue de 6,60 con mediana 6,50, indicando concentración en severidad media[³²]
- De los CVEs de código abierto analizados en 2025, solo el 36% tenía puntuación NVD; de los puntuados, menos de 1 de cada 5 era correcto: el 62% sobreestimaba la severidad y el 34% la subestimaba[³³]

La paradoja es reveladora: el sistema más utilizado del mundo para priorizar vulnerabilidades está operando, en gran medida, con datos incorrectos o ausentes.

7.2 La Diagnósis del Problema: Incentivos Rotos

El consultor Wim Remes, de la firma Torreón, ofrece quizás el diagnóstico más honesto del estado de la cuestión:[³⁴]

"Las organizaciones son reticentes a utilizar las métricas Threat, Environmental y Supplemental porque se ajustan principalmente por intuición. Preferimos confiar en lo que nos dice la herramienta antes que en lo que creemos que debería ser."

La raíz del problema es estructural: no existen incentivos suficientes para que los CNAs migren sus procesos de puntuación a v4 o retroactivamente puntúen CVEs existentes. Sin esa masa crítica de datos en v4, las organizaciones que adoptan CVSS 4.0 solo tienen acceso a una fracción mínima de vulnerabilidades con puntuación actualizada, lo que reduce el valor práctico inmediato del nuevo estándar para la priorización operacional.[³⁰]

8. CVSS 4.0 vs. Sistemas Alternativos: El Mapa del Territorio

La crítica más articulada a CVSS no proviene de sus detractores, sino del primer estudio empírico a gran escala que comparó los cuatro sistemas de puntuación más utilizados: CVSS, SSVC, EPSS e Exploitability Index, sobre 600 vulnerabilidades reales de Patch Tuesday (Microsoft, abril-julio 2024).[³⁵][³⁶]

8.1 El Diagnóstico Empírico

Los resultados son, cuando menos, incómodos para la comunidad:

- Los cuatro sistemas exhiben correlación muy baja entre sí (Pearson $r \approx 0$ en la mayoría de pares; Kappa de Cohen ≈ 0 , indicando acuerdo no mejor que el azar)
- Solo 5 vulnerabilidades de las 600 aparecen en el top-100 de los cuatro sistemas simultáneamente
- EPSS, el sistema de predicción de explotación, falló en predecir más del 80% de las vulnerabilidades del catálogo KEV (Known Exploited Vulnerabilities de CISA) antes de ser explotadas
- CVSS tiende a colocar >50% de los CVEs en sus tres bins superiores, generando sobrecarga de alertas

Sistema	Propósito	Limitación principal	Mejor uso
CVSS	Severidad técnica estándar	Agnóstico al entorno	Señal de severidad base
EPSS	Probabilidad de explotación (30 días)	Signal global, no contextualizada	Input de inteligencia de amenazas
SSVC	Triage orientado a decisión	Depende de inputs organizacionales precisos	Marco de gobernanza
CISA KEV	Explotación confirmada	Reactivo y limitado en alcance	Lista de revisión urgente
LEV	Probabilidad retrospectiva	Mirada hacia atrás	Análisis histórico

La conclusión del estudio es que "la falta de acuerdo entre sistemas deriva de la ausencia de un modelo conceptual compartido de riesgo de vulnerabilidad". Cada sistema optimiza para una faceta distinta del

problema, lo que implica que su combinación sinérgica —no su competencia— es el camino correcto.
[^35]

9. CVSS 4.0 para OT, ICS, IoT y Sectores Críticos

9.1 El Foco Industrial de v4.0

Uno de los mandatos explícitos del CVSS-SIG al diseñar v4.0 fue ampliar la cobertura hacia entornos que CVSSv3.x representaba deficientemente: sistemas de control industrial (ICS/SCADA), tecnología operacional (OT) e Internet de las Cosas (IoT). Las versiones anteriores habían sido diseñadas pensando principalmente en software IT convencional, donde la tríada CIA (Confidentiality/Integrity/Availability) es suficiente.[^37][^25]

En entornos industriales, la disponibilidad suele ser la dimensión más crítica (un sistema SCADA caído puede significar apagones o accidentes), y el impacto en sistemas subsecuentes físicos puede involucrar daños a personas. Las nuevas métricas Suplemental —especialmente **Safety y Recovery**— abordan directamente esta realidad:[^38][^25]

- **Safety: Present** → La explotación podría causar daño físico a humanos (aplicable a robótica industrial, sistemas de seguridad ferroviaria, equipos médicos, plantas energéticas)
- **Recovery: Irrecoverable** → El sistema no puede restaurar automáticamente su funcionamiento después del ataque (crítico para infraestructuras sin redundancia)
- **Value Density: Concentrated** → El atacante obtiene control sobre recursos críticos o de alto valor con una sola explotación (aplicable a SCADA central de una red eléctrica)

Para España, cuya Ley de Protección de Infraestructuras Críticas (Ley 8/2011) designa 12 sectores críticos bajo supervisión del CNPIC (Centro Nacional para la Protección de Infraestructuras Críticas), este refinamiento de CVSS 4.0 tiene implicaciones directas en la evaluación de riesgo de operadores críticos.[^39]

9.2 El Sector Sanitario: CVSS BTE en Dispositivos Médicos

La investigación publicada en *Health and Technology* (2025) representa el caso de estudio más riguroso de CVSS 4.0 aplicado a dispositivos médicos. El estudio demuestra que la puntuación Base puede resultar "un cuadro de una vulnerabilidad evaluado como de alto impacto que fácilmente puede malrepresentar el riesgo real del mundo real".[^40][^28]

El ejemplo CVE-2024-11053 (cURL) ilustra el problema con precisión quirúrgica: la vulnerabilidad recibió inicialmente un CVSS-B de 9.1 (Crítica), generando alarma en equipos de seguridad de hospitales que usaban cURL en dispositivos médicos conectados. Un análisis BTE completo, incorporando el contexto de despliegue real (redes hospitalarias segmentadas, ausencia de exploit funcional), producía una puntuación muy inferior, racionalizando la respuesta.[^28]

10. El Ecosistema Regulatorio Europeo como Motor de CVSS 4.0

10.1 NIS2: El Umbral Mínimo de Madurez

La Directiva NIS2 (Directiva UE 2022/2555), en vigor desde octubre de 2024, establece obligaciones de gestión de riesgos para entidades esenciales e importantes en 18 sectores críticos. Aunque NIS2 no prescribe explícitamente el uso de CVSS, sus requisitos de gestión de vulnerabilidades y notificación de incidentes en 24 horas crean un contexto en el que disponer de una metodología estructurada de puntuación es prácticamente imprescindible.^{[^41][^42]}

DORA (Digital Operational Resilience Act, Reglamento UE 2022/2554), en vigor desde enero de 2025, aplica al sector financiero europeo y exige notificación de incidentes mayores en 4 horas. La velocidad de notificación requerida hace que los sistemas de puntuación automática —y en particular la integración de CVSS con threat intelligence en tiempo real— sean operacionalmente críticos para bancos, aseguradoras e infraestructuras de mercados financieros. En España, la banca representa el 34% de los incidentes en operadores esenciales según INCIBE.^{[^6][^42][^41]}

10.2 EUVD: La Soberanía Europea de la Vulnerabilidad

En abril de 2025, ENISA lanzó oficialmente la **European Union Vulnerability Database (EUVD)**, mandatada por NIS2 y acelerada por la inestabilidad observada en el programa CVE/NVD de Estados Unidos. La EUVD:^{[^43][^44]}

- Agrega datos de CSIRTs nacionales, investigadores de amenazas y bases de datos existentes (incluyendo CVE/NVD)
- Enriquece los registros con puntuaciones CVSS y clasificaciones CWE^[^44]
- Asigna identificadores propios (por ejemplo, EUVD-2025-21128) a cada vulnerabilidad
- Incluye indicadores de explotación activa
- Opera como CNA propia dentro del ecosistema global, con ENISA como CVE Root^[^45]

La EUVD no pretende reemplazar el CVE sino complementarlo: es la contraparte europea del NVD, pero con gobernanza comunitaria y orientada a las necesidades regulatorias europeas. Para España, esto significa que INCIBE y el CCN-CERT pueden alimentarse de una fuente de inteligencia de vulnerabilidades soberana, reduciendo la dependencia de decisiones presupuestarias del NIST estadounidense —cuya crisis de financiación en 2024 originó el colapso del backlog NVD.^{[^46][^44]}

10.3 Cyber Resilience Act (CRA): Obligaciones desde Septiembre de 2026

El Reglamento UE 2024/2847 (Cyber Resilience Act), adoptado en octubre de 2024, establece a partir del **11 de septiembre de 2026** la obligación de los fabricantes de reportar a ENISA las vulnerabilidades activamente explotadas en sus productos dentro de las **24 horas** de su conocimiento. La notificación completa debe producirse en 72 horas. Este marco crea, por primera vez en Europa, un flujo obligatorio de información sobre vulnerabilidades explotadas que alimentará directamente la EUVD y los sistemas nacionales de gestión.^{[^47][^48]}

Para los consumidores de CVSS, el CRA tiene una implicación práctica inmediata: la disponibilidad de datos de explotación activa —el insumo clave para la métrica **Exploit Maturity (E)** de CVSS 4.0—

aumentará significativamente, haciendo que el enriquecimiento de vectores CVSS-BT sea más viable y menos dependiente de fuentes comerciales de threat intelligence.[¹³]

11. Aplicación Territorial en España: Las Administraciones Públicas como Terreno de Pruebas

11.1 El Marco Normativo Nacional: ENS como Columna Vertebral

El **Esquema Nacional de Seguridad** (ENS), regulado por el Real Decreto 311/2022, constituye el marco normativo de obligatorio cumplimiento para toda la Administración Pública española. Su ámbito es amplio:[²⁴][²³]

- Administración General del Estado (AGE)
- Comunidades Autónomas (CCAA) y sus organismos dependientes
- Entidades Locales (ayuntamientos, diputaciones, cabildos)
- Universidades públicas
- Mutuas colaboradoras con la Seguridad Social
- Empresas privadas que presten servicios a entidades públicas[⁴⁹][⁵⁰]

El ENS categoriza los sistemas en BAJO, MEDIO y ALTO según el impacto que su perturbación causaría, y establece controles de seguridad proporcionales. Esta categorización se alinea directamente con las **métricas ambientales CR/IR/AR** de CVSS 4.0: los sistemas ENS Alto deberían recibir CR: High, IR: High, AR: High en sus evaluaciones CVSS, mientras que sistemas ENS Bajo podrían justificar requisitos reducidos.[²³]

La Guía CCN-STIC 817 —*Gestión de Ciberincidentes en el ENS*— establece la clasificación operativa de incidentes en **9 tipos y 36 subcategorías**, con 5 niveles de impacto (I0-I5, de irrelevante a crítico). Aunque esta taxonomía es paralela al sistema CVSS (uno clasifica el incidente *ocurrido*, el otro clasifica la vulnerabilidad *potencial*), ambos marcos se complementan en la cadena de gestión de riesgo del sector público.[⁵¹][⁵²]

11.2 La Arquitectura Institucional de Respuesta

España ha construido una arquitectura dual de respuesta cibernética que distingue ámbitos de actuación:

CCN-CERT (Centro Criptológico Nacional): Coordinación de incidentes para toda la Administración Pública. Emite las guías CCN-STIC, opera la Red Nacional de SOC, gestiona la plataforma INES (Informe Nacional del Estado de Seguridad) y proporciona capacidades técnicas avanzadas. En 2025, el CCN gestionó **más de 200.000 incidentes**, de los cuales **278 fueron críticos** (+293% respecto al año anterior), incluyendo 128 casos de ciberespionaje.[⁵³][⁵⁴][⁵⁵]

INCIBE-CERT: Respuesta para ciudadanos, empresas del sector privado, proveedores de servicios digitales y operadores esenciales del sector privado. INCIBE es la referencia nacional en la aplicación operativa de CVSS: su portal de alerta temprana clasifica cada nueva vulnerabilidad con puntuación CVSS v4.0, incluyendo el vector completo.[⁷][⁵⁶][⁴]

Red Nacional de SOC (RNS): Plataforma coordinada por el CCN-CERT que integra más de **250 Centros de Operaciones de Seguridad** interconectados —públicos y privados— a escala nacional. La RNS comparte en tiempo real:[^9]

- Métricas de vulnerabilidades e incidentes
- Reglas de detección y casos de uso
- Listas de dominios sospechosos e indicadores de compromiso (IOA/IOC)
- Inteligencia sobre TTPs de amenazas activas[^8]

Esta infraestructura representa el mecanismo a través del cual las métricas CVSS —especialmente las Threat metrics enriquecidas con inteligencia nacional— se diseminan operativamente por todo el territorio.

11.3 Comunidades Autónomas: El Mapa de la Exposición

El panorama de incidentes en las CCAA durante 2025 refleja una dispersión geográfica del riesgo que dificulta una respuesta puramente centralizada:

Cataluña es la comunidad con datos más sistematizados: la Agencia de Ciberseguridad de Cataluña reportó que en 2024 la Generalitat combatió **6.900 millones de ataques** dirigidos a más de 300 entidades del sector público (hospitales, universidades, ayuntamientos, departamentos del Govern), de los cuales **3.372 fueron exitosos** causando daños. Las universidades concentraron el 66% de los incidentes exitosos, por el uso de dispositivos personales de estudiantes en redes corporativas.[^57]

Madrid, Andalucía y País Vasco son identificadas como las comunidades más activas en capacidades de ciberseguridad propias, aunque también objetivos frecuentes. La Asamblea de la Comunidad de Madrid, la Diputación de Guipúzcoa y múltiples ayuntamientos vascos sufrieron ataques DDoS y de acceso no autorizado en 2025.[^58][^59][^60]

Extremadura, Castilla y León y Valencia protagonizaron algunos de los incidentes más mediáticos del año: el Ayuntamiento de Badajoz fue paralizado por un ataque ransomware LockBit en abril de 2025, afectando a una población de 150.000 habitantes. La Consejería de Educación de Castilla y León sufrió compromiso de datos personales y confidenciales. La Comunidad Valenciana había sido afectada previamente por accesos no autorizados a plataformas de salud electrónica.[^61][^59][^62]

Administración/CCAA	Tipo de incidente 2025	Referencia
Generalitat de Cataluña	6.900M ataques; 3.372 exitosos (2024)	[^57]
Ayuntamiento de Badajoz	Ransomware LockBit; servicios paralizados	[^59]
Ayuntamiento de Melilla	Ransomware; servicios municipales días	[^62]
Diputación de Guipúzcoa	DDoS prorruso (NoName057)	[^60]
Ayuntamiento de San Sebastián/Irún	DDoS	[^59]
Consejería Educación C. León	Compromiso de datos	[^62]
Comunidad Valenciana (salud)	Acceso no autorizado HCE	[^61]
Sector sanitario (nacional)	>2.400 ciberataques/semana	[^63]

11.4 El Problema de la Métrica Ambiental en el Sector Público Español

La aplicación plena de CVSS 4.0 en la Administración Pública española choca con obstáculos estructurales bien documentados:

Ausencia de Asset Management Databases (CMDB) actualizadas: La guía de implementación FIRST es explícita al respecto: las métricas ambientales requieren conocimiento preciso del inventario de activos, topología de red, controles implementados y requisitos de negocio. Las administraciones locales —especialmente ayuntamientos y diputaciones de municipios pequeños— carecen frecuentemente de este inventario, lo que hace imposible calcular puntuaciones CVSS-BE o CVSS-BTE significativas.[^15]

Dependencia de puntuaciones Base como puntuaciones finales: La práctica habitual —no exclusiva de España, sino global— es utilizar el CVSS-B publicado por el fabricante o NVD como si fuera la evaluación definitiva. Sin enriquecimiento con métricas Threat y Environmental, el CVSS se convierte en un indicador de severidad decontextualizado, incapaz de reflejar que un sistema ENS Alto sin parche disponible en un hospital es cualitativamente distinto del mismo sistema sin parche en una intranet administrativa de bajo impacto.[^64]

Fragmentación de capacidades entre niveles de administración: La Red Nacional de SOC agrupa a más de 250 entidades, pero la realidad es que muchos ayuntamientos y entes locales no cuentan con SOC propio y dependen de servicios gestionados. Esta asimetría de capacidades implica que la aplicación de métricas contextuales CVSS es cualitativamente diferente entre la AGE (con equipos dedicados y herramientas avanzadas) y los pequeños municipios (con recursos de seguridad mínimos).[^65]

11.5 Intersección ENS-CVSS 4.0: Una Propuesta de Alineamiento

El ENS y CVSS 4.0 comparten una filosofía común: la proporcionalidad basada en el análisis de riesgo. El ENS requiere que cada organización categorice sus sistemas y aplique controles proporcionales a esa categoría; CVSS 4.0 invita a los consumidores a ajustar las puntuaciones Base con el contexto de su entorno específico.[^66][^24]

La alineación natural es la siguiente:

Categoría ENS	Implicación CVSS 4.0
ALTO	CR/IR/AR: High; priorización máxima de remediación; Threat metrics obligatorias
MEDIO	CR/IR/AR: Medium; remediación en ciclos definidos; Threat metrics recomendadas
BAJO	CR/IR/AR: Low; remediación según recursos disponibles; CVSS-B como orientación

Un sistema ENS Alto comprometido implica, por definición, "perjuicio grave o muy grave a los intereses nacionales o a las personas". Traducido al lenguaje CVSS 4.0: Availability Requirements High, Safety potencialmente Present, Value Density Concentrated. La puntuación CVSS-BTE resultante para ese sistema será sistemáticamente superior a la del CVSS-B publicado por el proveedor, lo que justifica respuestas más agresivas.[^23]

12. El Horizonte: IA, Automatización y el CVSS del Futuro

12.1 LLMs para Puntuación Automática: Del Laboratorio a la Operación

El cuello de botella más crítico del ecosistema CVSS —el retraso entre la publicación del CVE y la asignación de puntuación— está siendo abordado por múltiples grupos de investigación mediante Large Language Models (LLMs). En 2025–2026, varios trabajos relevantes han demostrado el potencial de esta aproximación:

JewelCVSS (BV TECH / CyberLab, Italia), presentado en ICAART 2026 en Marbella y ganador del *Best Industrial Paper Award*, propone un LLM ajustado específicamente para el dominio de la ciberseguridad que predice la puntuación CVSS con alta precisión a partir de la descripción textual del CVE. El modelo es capaz de proporcionar una estimación de severidad *inmediatamente tras la publicación del CVE*, antes de que ningún analista humano haya procesado la información.[^67][^68][^69]

AutoCVSS (NEC Research, EMNLP 2025) demuestra que los LLMs son especialmente valiosos en escenarios de escasez de datos etiquetados —como durante la transición a nuevas versiones del estándar— donde los modelos supervisados tradicionales no tienen suficientes ejemplos de entrenamiento.[^70]

Un estudio publicado en *IJET* (2026) evaluó tres modelos chatbot (ChatGPT-4o-mini, Gemini 2.0 Flash, DeepSeek Chat) sobre 4.459 registros CVE para automatizar la puntuación CVSS 3.1. Gemini alcanzó la mayor precisión, pero todos los modelos mostraron inconsistencias entre vector y puntuación que requieren mecanismos de validación. La conclusión es que los LLMs pueden *asistir* a los analistas, pero no sustituirlos sin supervisión.[^71]

Knowledge-Driven LLMs for Automating CVSS Scoring (ACM, 2025) propone integrar grafos de conocimiento de ciberseguridad con LLMs para mejorar la interpretación semántica de las descripciones de vulnerabilidad.[^72]

La convergencia de estas investigaciones apunta hacia un futuro próximo en el que la puntuación CVSS Base —y posiblemente las métricas Threat— se calculen de forma automatizada y casi en tiempo real, reduciendo el retraso de semanas (actualmente de más de 6 semanas en promedio entre publicación y scoring NVD) a minutos.^[^33]

12.2 CVSS y la Convergencia IT/OT en España

España es el segundo país del mundo con más centros de ciberseguridad, solo por detrás de Estados Unidos, según el informe de la UIT 2024 citado por el Gobierno. La inversión de 1.157 millones de euros aprobada en mayo de 2025 incluye explícitamente la integración de **técnicas de Inteligencia Artificial** en sistemas de detección de ciberataques y la protección de sistemas OT/SCADA.^{[^73][^58]}

En este contexto, el 5G Security Operations Center (5G SOC) —desplegado para monitorizar la ciberseguridad de redes 5G— y el Centro de Operaciones de Ciberseguridad (COCS) de la Secretaría General de Administración Digital son las infraestructuras donde la integración de CVSS 4.0 con threat intelligence en tiempo real tiene mayor potencial transformador.^[^74]

El 85% de las botnets identificadas por INCIBE-CERT en 2025 estaban relacionadas con dispositivos IoT (televisores, decodificadores, reproductores multimedia), lo que sitúa las métricas Supplemental de **Automatability** y **Value Density** en el centro de la priorización de vulnerabilidades en entornos domésticos y corporativos convergentes.^[^5]

12.3 La EUVD como Infraestructura de Soberanía Digital

El lanzamiento de la EUVD en abril de 2025 puede tener consecuencias más profundas de lo que aparenta en el corto plazo. Al constituirse ENISA como *CVE Root*, Europa establece su propia cadena de autoridad para la asignación y gestión de identificadores de vulnerabilidad. Esto implica que, a medida que el CRA entre en vigor (septiembre 2026), el flujo de datos de explotación activa que alimenta la métrica **Exploit Maturity** de CVSS 4.0 tendrá una fuente europea soberana, coordinada con los CSIRTs nacionales —incluidos CCN-CERT e INCIBE-CERT.^{[^75][^48][^45]}

Para España, la EUVD se convierte en un nodo de inteligencia de vulnerabilidades que puede alimentar directamente los sistemas de análisis del CCN y de la Red Nacional de SOC, cerrando el ciclo entre la publicación de la vulnerabilidad, la asignación de puntuación CVSS 4.0 enriquecida y la respuesta coordinada a nivel territorial.

13. Limitaciones Documentadas y Crítica Razonada

La honestidad intelectual exige reconocer que CVSS 4.0, pese a sus mejoras sustanciales, no es la solución definitiva al problema de la gestión de vulnerabilidades. Las limitaciones documentadas en la literatura científica reciente son:

1. Severidad no equivale a riesgo. El NVD lo declara explícitamente: "CVSS no es una medida de riesgo". Confundir ambos conceptos —algo que ocurre sistemáticamente en la práctica— produce decisiones de priorización subóptimas. Una vulnerabilidad CVSS 9.8 en un sistema desconectado de internet es menos urgente que una CVSS 6.0 en un sistema expuesto con exploit activo.^[^2]

2. La complejidad creciente desincentiva el uso correcto. El estudio de la Universidad de Twente (Ewadiirect, 2024) señala que la granularidad añadida de CVSS 4.0, aunque teóricamente superior, puede resultar abrumadora para equipos sin recursos suficientes para implementarla correctamente. La paradoja: el sistema más preciso puede producir peores resultados que el más simple si la fuerza laboral no tiene capacidad de usarlo apropiadamente.^[^76]

3. La fragmentación de versiones genera inconsistencia sistémica. Aproximadamente el 25% de los CVEs cambian de nivel de severidad al pasar de v3.x a v4.0. Las políticas organizacionales basadas en umbrales fijos (por ejemplo, "parchear todo CVSS ≥ 7.0 en 48 horas") producen conjuntos de trabajo radicalmente distintos según la versión usada, sin que la diferencia refleje necesariamente un cambio en el riesgo real.^[^29]

4. La adopción tardía de v4 mantiene vigente v3.x. Con solo el 2,4% de CVEs con puntuación v4 disponible, las organizaciones que migren completamente a CVSS 4.0 operan con datos fragmentarios. La recomendación pragmática de Nucleus Security —"seguir con v3.1 puede ser la elección pragmática por ahora"— refleja el dilema operacional real.^[^30]

5. Los sistemas alternativos son complementarios, no rivales. La investigación empírica demuestra que CVSS, EPSS, SSVC y KEV ofrecen perspectivas distintas y parcialmente contradictorias sobre el riesgo de cada vulnerabilidad. Tratar cualquiera de ellos como la fuente única de verdad es una receta para el error.^{[^77][^35]}

14. Recomendaciones Estratégicas para el Sector Público Español

Basadas en la evidencia acumulada, las siguientes recomendaciones se dirigen específicamente al contexto del sector público español:

Para Organismos de la AGE y CCAA con Capacidades SOC Propias

5.
Adoptar la nomenclatura CVSS-BTE como estándar de comunicación interno, abandonando la referencia exclusiva a CVSS-B. Documentar explícitamente qué grupos de métricas se han incorporado en cada evaluación.
6.
Implementar el ciclo de vida de enriquecimiento CVSS descrito en la Consumer Implementation Guide (FIRST, enero 2026): Base (proveedor) → Threat (threat intelligence nacional, EUVD, INCIBE-CERT) → Environmental (CMDB, controles ENS validados) → Supplemental (Safety para sistemas con impacto físico).[^15]
7.
Alinear CR/IR/AR con la categorización ENS: Los sistemas ENS Alto reciben CR/IR/AR: High; Medio reciben CR/IR/AR: Medium. Esta alineación convierte la categorización ENS obligatoria en insumo directo para la puntuación CVSS.
8.
Integrar la EUVD como fuente primaria de inteligencia de vulnerabilidades, complementando NVD con datos de CSIRTs europeos y métricas de explotación activa que actualizan la métrica Exploit Maturity.
9.
Explorar herramientas de puntuación automática (AutoCVSS, JewelCVSS u equivalentes) para reducir el retraso entre publicación de CVE y asignación de puntuación, especialmente para el largo cola de vulnerabilidades de bajo y medio impacto.

Adoptar la nomenclatura CVSS-BTE como estándar de comunicación interno, abandonando la referencia exclusiva a CVSS-B. Documentar explícitamente qué grupos de métricas se han incorporado en cada evaluación.

Implementar el ciclo de vida de enriquecimiento CVSS descrito en la Consumer Implementation Guide (FIRST, enero 2026): Base (proveedor) → Threat (threat intelligence nacional, EUVD, INCIBE-CERT) → Environmental (CMDB, controles ENS validados) → Supplemental (Safety para sistemas con impacto físico).[^15]

Alinear CR/IR/AR con la categorización ENS: Los sistemas ENS Alto reciben CR/IR/AR: High; Medio reciben CR/IR/AR: Medium. Esta alineación convierte la categorización ENS obligatoria en insumo directo para la puntuación CVSS.

Integrar la EUVD como fuente primaria de inteligencia de vulnerabilidades, complementando NVD con datos de CSIRTs europeos y métricas de explotación activa que actualizan la métrica Exploit Maturity.

Explorar herramientas de puntuación automática (AutoCVSS, JewelCVSS u equivalentes) para reducir el retraso entre publicación de CVE y asignación de puntuación, especialmente para el largo cola de vulnerabilidades de bajo y medio impacto.

Para Entidades Locales con Recursos Limitados

10.

Usar CVSS como señal de severidad base, no como métrica de riesgo definitiva. Complementar con la lista CISA KEV (adaptada a contexto europeo mediante EUVD) para identificar las vulnerabilidades con explotación confirmada que requieren respuesta inmediata.

11.

Delegar la gestión CVSS-BTE en el SOC gestionado contratado, exigiendo contractualmente que el proveedor aplique métricas Threat y Environmental con el contexto específico del sistema municipal, y no meramente reporte CVSS-B.

12.

Notificar a INCIBE-CERT los sistemas vulnerables detectados, alimentando el sistema de alerta temprana nacional que en 2025 identificó 237.028 sistemas vulnerables en España.^[^5]

Usar CVSS como señal de severidad base, no como métrica de riesgo definitiva. Complementar con la lista CISA KEV (adaptada a contexto europeo mediante EUVD) para identificar las vulnerabilidades con explotación confirmada que requieren respuesta inmediata.

Delegar la gestión CVSS-BTE en el SOC gestionado contratado, exigiendo contractualmente que el proveedor aplique métricas Threat y Environmental con el contexto específico del sistema municipal, y no meramente reporte CVSS-B.

Notificar a INCIBE-CERT los sistemas vulnerables detectados, alimentando el sistema de alerta temprana nacional que en 2025 identificó 237.028 sistemas vulnerables en España.^[^5]

Para el Ecosistema Nacional (CCN, INCIBE, CNPIC)

13.

Promover incentivos para la adopción de CVSS v4 por parte de los CNAs y fabricantes de software de uso común en la administración pública española, replicando en contexto nacional el problema identificado a escala global.^[^30]

14.

Desarrollar perfiles de puntuación CVSS-BTE sectoriales para infraestructuras críticas (energía, transporte, sanidad, agua) que permitan a los operadores aplicar métricas ambientales estandarizadas según su sector, reduciendo la complejidad de implementación.

Promover incentivos para la adopción de CVSS v4 por parte de los CNAs y fabricantes de software de uso común en la administración pública española, replicando en contexto nacional el problema identificado a escala global.^[^30]

Desarrollar perfiles de puntuación CVSS-BTE sectoriales para infraestructuras críticas (energía, transporte, sanidad, agua) que permitan a los operadores aplicar métricas ambientales estandarizadas según su sector, reduciendo la complejidad de implementación.

Conclusión: La Puntuación como Conversación, No como Oráculo

CVSS 4.0 es, en esencia, una invitación a una conversación más sofisticada sobre riesgo. Sus métricas Base ofrecen el vocabulario compartido; sus métricas Threat y Environmental aportan el contexto que convierte ese vocabulario en inteligencia accionable; sus métricas Supplemental introducen dimensiones —seguridad humana, recuperabilidad, automatizabilidad— que reconocen que el impacto de una vulnerabilidad trasciende la tríada CIA clásica.^[^78]^[^13]

En el territorio español, ese diálogo se libra en los 250 SOC de la Red Nacional, en los sistemas de alerta temprana de INCIBE, en los informes del CCN-CERT y en los escritorios de los responsables de seguridad de 8.131 municipios, 17 comunidades autónomas y centenares de organismos estatales que deben gestionar, con recursos siempre limitados, un ecosistema de vulnerabilidades que en 2025 superó los 48.000 CVEs publicados y los 237.000 sistemas vulnerables detectados solo en territorio nacional.^[^5]^[^32]

El desafío no es técnico en su raíz: es organizacional, presupuestario y cultural. CVSS 4.0 proporciona las herramientas. El sector público español tiene la arquitectura institucional —ENS, CCN-CERT, INCIBE, Red Nacional de SOC— para usarlas. La brecha entre ambos extremos es el espacio donde la ciberseguridad territorial del siglo XXI se juega su partida más decisiva.

References

15.
Common Vulnerability Scoring System - Wikipedia
16.
NVD
17.
Common Vulnerability Scoring System SIG
18.
Vulnerabilidad en Directory Services (CVE-2025-15579) - INCIBE - Vulnerabilidad de deserialización de datos no confiables en OpenText™ Directory Services permite la ...
19.
INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un 26% más que el año anterior · Malwa...
20.
INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 · Banca: 34% · Transporte: 14% · ...
21.
CVE-2025-41090 | INCIBE-CERT - Impacto ; Puntuación base: 7.60 ALTA ; Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:N/VC:H/VI:H/VA:L/SC:N...
22.
RNS - plataformanacionalciber.gob.es - Iniciativa impulsada por el Centro Criptológico Nacional para integrar y coordinar los Centros de Op...
23.
Así opera la red de 250 SOC que combate el cibercrimen en ... - La Red Nacional de SOC permite compartir inteligencia en tiempo real, estandarizar la respuesta ante...
24.
What Is Common Vulnerability Scoring System (CVSS)? - Fortinet - It assesses vulnerabilities and scores them using the common vulnerability scoring system (CVSS). Cy...
25.
Impact of the transition from the CVSSv3 to CVSSv4 norm - Discover how the shift from CVSSv3.1 to CVSSv4.0 impacts vulnerability scoring, prioritization, and ...

26.
CVSS v4.0 User Guide - This guide supplements the Common Vulnerability Scoring System (CVSS) version 4.0 Specification Docu...
27.
CVSS v4.0 Specification Document - The Common Vulnerability Scoring System (CVSS) is an open framework for communicating the characteri...
28.
Understanding CVSS and What's New in Version 4.0 - Blog - Cyrisma - CVSS includes four metric groups: Base, Threat, Environmental, and Supplemental. Base Metrics. Base ...
29.
CVSS v4.0 Consumer Implementation Guide - The CVSS SIG strongly recommends bringing Threat and Environmental metrics into the CVSS lifecycle t...
30.
Common Vulnerability Scoring System v3.1: Specification Document - CVSS is composed of three metric groups: Base, Temporal, and Environmental. The Base Score reflects ...
31.
CVSS v4.0: What You Need to Know about the Latest Version - CVSS v4.0 introduces significant improvements in severity assessment and scoring, aiming to provide ...
32.
Unpacking CVSS 4.0 and vulnerability risk - Red Canary - The latest version of the Common Vulnerability Scoring System (CVSS) features updated metric groupin...
33.
Common Vulnerability Scoring System (CVSS) - CrowdStrike - The CVSS is a standardized way to calculate the severity of security vulnerabilities. Security profe...
34.
CVSS v4.0 Examples - This document demonstrates how to apply the CVSS version 4.0 standard to assess specific vulnerabili...
35.
Understanding CVSS 4.0 and the Future of Vulnerability Scoring - Explore what's new in CVSS 4.0, how it changes vulnerability scoring, and what's next for risk asses...

36.
CVSS v4 Explained: Key Changes & Impact - Qualys Blog - CVSS 4.0 represents a decent upgrade compared to CVSS 3.1, primarily due to the renaming of key metr...
37.
Esquema Nacional de Seguridad - Wikipedia, la enciclopedia libre
38.
BOE-A-2022-7191 Real Decreto 311/2022, de 3 de mayo, por el ... - En tercer lugar, facilitar una mejor respuesta a las tendencias en ciberseguridad, reducir vulnerabi...
39.
What is the Common Vulnerability Scoring System (CVSS)? - PlexTrac - CVSS scores are calculated based on vulnerability characteristics in four metric groups: Base, Threa...
40.
CVSS Version 4.0: What's New - Sysdig - FIRST recently announced the CVSS 4.0 Public Preview with a target official publication date of Oct....
41.
CVSS v4.0 Frequently Asked Questions - The Common Vulnerability Scoring System (CVSS) is an open framework for communicating the characteri...
42.
Quantifying medical device cybersecurity risk with CVSS BTE - Nature - This study is based on the new CVSS standard, version 4.0, released on November 1, 2023. As of today...
43.
CVSS Fragmentation | Michał Walkowski - Monthly snapshot of NVD CVSS coverage, intersections, and severity distributions across CVSS v2.0, v...
44.
CVSS v4 adoption is low due to lack of incentives - LinkedIn - It's been 1.5 years since the initial release of FIRST CVSS v4 in November 2023, yet only 2.4% of CV...
45.
NVD CVE Analysis Rate Report - At the time of this reports generation, NVD's 2025 daily average for analyzing new CVEs is 115.22. T...

46.
2025 CVE Data Review - JerryGamblin.com - The average CVSS score for 2025 was 6.60, with a median of 6.50. This indicates a concentration of v...
47.
Sonatype Intelligence Reveals CVE Program Leaves Majority of Vulnerabilities Unscored - Inconsistent and delayed open source vulnerability data results in 150,000 false negatives, leaving ...
48.
CVSS Scores No Longer Enough: The Move to Context-Driven ... - Vulnerability scoring models such as CVSS 3.1 and CVSS 4.0 must evolve to include contextual informa...
49.
An Empirical Study of Vulnerability Scoring Systems - Moonlight - This paper presents the first large-scale, outcome-linked empirical comparison of four prominent and...
50.
An Empirical Study of Vulnerability Scoring Systems - Accurately assessing software vulnerabilities is essential for effective prioritization and remediat...
51.
CVSS 4.0 keys-in on threat intelligence metrics and OT, ICS and IoT - ... CVSS 4.0 focuses on base metrics for operational technology (OT), industrial control systems (IC...
52.
The New CVSS 4.0 for OT / ICS / IoT - Radiflow - The CVSS score is represented simply as a number from 0 – 10 that represents the severity of a secur...
53.
La Directiva NIS2
54.
Health and Technology (2025) 15:635–650
55.
DORA vs NIS2: Key Differences, Overlaps, and Compliance Impact - DORA (Digital Operational Resilience Act) is an EU regulation that has applied directly in EU member...
56.
DORA & NIS2 compliance: Strengthening cybersecurity in 2025 - The NIS2 directive and DORA regulations represent key advancements in the European Union's efforts t...

57.
Enisa launches European vulnerability database - Computer Weekly - The EU's new vulnerability database is designed to offer a broader, more transparent source of infor...
58.
How to Use Europe's New Vulnerability Database - The European Cybersecurity Agency (ENISA) officially launched the European Union Vulnerability Datab...
59.
November/December 2025 Critical Updates - Cyber Resilience Act - For the last few years, the Cyber Resilience Act (CRA) has been a topic of high-level policy debate....
60.
Vulnerability Exposure & Severity Trends in 2025 - Appsecure Security - Explore 2025 vulnerability exposure and severity trends across web, cloud, APIs, and infrastructure....
61.
Cyber Resilience Act: Overview for affected companies - From 11 September 2026, manufacturers must report any actively exploited vulnerability they become a...
62.
Cyber Resilience Act - Reporting obligations - As of 11 September 2026, manufacturers are required to report actively exploited vulnerabilities and...
63.
[PDF] RECOMENDACIÓN ESQUEMA NACIONAL DE SEGURIDAD ...
64.
Esquema Nacional de Seguridad: Guía completa de ... - Audidat - El Esquema Nacional de Seguridad (ENS) es clave. Descubre qué es, su obligatoriedad, categorías y la...
65.
[PDF] PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD ... - El artículo 11 de Esquema Nacional de Seguridad (ENS) señala la obligación de que las entidades públ...
66.
ENS y la gestión de incidentes de ciberseguridad - ESED - Una clasificación estructurada de nueve tipos de ciberincidentes, divididos en 36 subcategorías, que...
67.
[PDF] Guía de Seguridad de las TIC CCN-STIC 817 ESQUEMA ... - AEC

68.
Los incidentes críticos en España por ciberespionaje y cibercrimen ... - El Centro Criptológico Nacional del CNI ha gestionado más de 200.000 incidentes de ciberseguridad en...
69.
La ciberseguridad y su relevancia en el Sector Público. ...
70.
Respuesta 24x7 para Infraestructuras Críticas | INCIBE-CERT - Entre los servicios puestos en marcha en el marco de INCIBE-CERT destaca la respuesta ante incidente...
71.
La Generalitat combatió 6.900 millones de ciberataques en 2024, 3.372 de ellos dañinos - La Generalitat combatió en 2024 un total de 6.900 millones de ciberataques enviados por piratas info...
72.
[PDF] Informe Ciberseguridad 2025 | PTE Disruptive - En 2025, la ciberseguridad ha dejado de ser un asunto meramente tecnológico para convertirse en un p...
73.
Marzo 2025: Ataque prorruso... - Siguen proliferando los ciberataques en España en 2025. El año ha empezado con noticias de ataques a...
74.
Ataques informáticos en 2025: los 6 casos más graves en España - Los ataques informáticos crecen en 2025: Conoce los casos más graves en España y cómo proteger tus d...
75.
Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...
76.
España, bajo asedio digital: ciberataques golpean a gobiernos y ... - España ha vivido un primer semestre de 2025 marcado por una oleada de ciberataques que han puesto en...
77.
La próxima gran crisis será en 2026: hospitales y ayuntamientos, en ... - 2025 ha servido para poner los pies en la tierra. Los ciberataques ya no van solo de robar informaci...

78.
Stop Demonizing CVSS: Fix the Real Problem - Nucleus Security - Demonizing CVSS distracts from real issues in vulnerability management. Learn why operational challe...
79.
Red Nacional de SOC (RNS) - Métricas e indicadores a utilizar en un SOC para mejorar su gestión; Listas blancas con ubicaciones ...
80.
Spain Esquema Nacional de Seguridad (ENS) High-Level Security ... - It guides these agencies and companies in implementing effective controls for security in the cloud ...
81.
SCIENCE AND TECHNOLOGY PUBLICATIONS - SCITEPRESS - Accurately predicting the Common Vulnerability Scoring System (CVSS) score from Common Vulnerability...
82.
Nuovo rapporto di ricerca accettato per la presentazione a ICAART ... - The research report “JewelCVSS: A Domain-Tuned LLM for Automated Vulnerability Scoring”, carried out...
83.
Assegnato a BV TECH il “Best Industrial Paper Award” della ... - ... 2026, the “Best Industrial Paper Award” was awarded to BV TECH for the research report “JewelCVS...
84.
Assessing the Performance of LLMs for Automated Software ... - This study explores leveraging Large Language Models (LLMs) for automating vulnerability risk score ...
85.
[PDF] Application of Large Language Models to Automatic Classification of ...
86.
Knowledge-Driven Large Language Models for Automating CVSS ... - To automate vulnerability scoring, some researchers have used machine learning models to predict CVS...
87.
The Government approves a strengthening of Spain's cybersecurity ... - The Council of Ministers today approved a set of actions in cybersecurity and cyberdefence that comp...

88.

Despliegue y Operación del Centro de ... - España Digital - Asimismo, el Centro Criptológico Nacional (CCN-CERT) pone a disposición su capacidad de operación de...

89.

Vulnerability Coordination under the Cyber Resilience Act - The paper examines and elaborates the CRA's new requirements for vulnerability coordination, includi...

90.

A comprehensive review on the application of CVSS 4.0 and deep ... - This paper reviews the evolution of the Common Vulnerability Scoring System (CVSS), focusing on the ...

91.

Comparing CVSS, EPSS, KEV, SSV, and PXS - Picus Security - Compare CVSS, EPSS, KEV, SSV, LEV & PXS. Understand each model's value, and why proof of exploitabi...

92.

How CVSS v4.0 works: characterizing and scoring vulnerabilities - What's new in CVSS v4.0? · 1. Expanded metric groups · 2. Refined scoring and terminology · 3. Great...

Common Vulnerability Scoring System - Wikipedia

NVD

Common Vulnerability Scoring System SIG

Vulnerabilidad en Directory Services (CVE-2025-15579) - INCIBE - Vulnerabilidad de deserialización de datos no confiables en OpenText™ Directory Services permite la ...

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un 26% más que el año anterior · Malwa...

INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 · Banca: 34% · Transporte: 14% · ...

CVE-2025-41090 | INCIBE-CERT - Impacto ; Puntuación base: 7.60 ALTA ; Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:N/VC:H/VI:H/VA:L/SC:N...

RNS - plataformanacionalciber.gob.es - Iniciativa impulsada por el Centro Criptológico Nacional para integrar y coordinar los Centros de Op...

Así opera la red de 250 SOC que combate el cibercrimen en ... - La Red Nacional de SOC permite compartir inteligencia en tiempo real, estandarizar la respuesta ante...

What Is Common Vulnerability Scoring System (CVSS)? - Fortinet - It assesses vulnerabilities and scores them using the common vulnerability scoring system (CVSS). Cy...

Impact of the transition from the CVSSv3 to CVSSv4 norm - Discover how the shift from CVSSv3.1 to CVSSv4.0 impacts vulnerability scoring, prioritization, and ...

CVSS v4.0 User Guide - This guide supplements the Common Vulnerability Scoring System (CVSS) version 4.0 Specification Docu...

CVSS v4.0 Specification Document - The Common Vulnerability Scoring System (CVSS) is an open framework for communicating the characteri...

Understanding CVSS and What's New in Version 4.0 - Blog - Cyrisma - CVSS includes four metric groups: Base, Threat, Environmental, and Supplemental. Base Metrics. Base ...

CVSS v4.0 Consumer Implementation Guide - The CVSS SIG strongly recommends bringing Threat and Environmental metrics into the CVSS lifecycle t...

Common Vulnerability Scoring System v3.1: Specification Document - CVSS is composed of three metric groups: Base, Temporal, and Environmental. The Base Score reflects ...

CVSS v4.0: What You Need to Know about the Latest Version - CVSS v4.0 introduces significant improvements in severity assessment and scoring, aiming to provide ...

Unpacking CVSS 4.0 and vulnerability risk - Red Canary - The latest version of the Common Vulnerability Scoring System (CVSS) features updated metric groupin...

Common Vulnerability Scoring System (CVSS) - CrowdStrike - The CVSS is a standardized way to calculate the severity of security vulnerabilities. Security profe...

CVSS v4.0 Examples - This document demonstrates how to apply the CVSS version 4.0 standard to assess specific vulnerabili...

Understanding CVSS 4.0 and the Future of Vulnerability Scoring - Explore what's new in CVSS 4.0, how it changes vulnerability scoring, and what's next for risk asses...

CVSS v4 Explained: Key Changes & Impact - Qualys Blog - CVSS 4.0 represents a decent upgrade compared to CVSS 3.1, primarily due to the renaming of key metr...

Esquema Nacional de Seguridad - Wikipedia, la enciclopedia libre

BOE-A-2022-7191 Real Decreto 311/2022, de 3 de mayo, por el ... - En tercer lugar, facilitar una mejor respuesta a las tendencias en ciberseguridad, reducir vulnerabi...

What is the Common Vulnerability Scoring System (CVSS)? - PlexTrac - CVSS scores are calculated based on vulnerability characteristics in four metric groups: Base, Threa...

CVSS Version 4.0: What's New - Sysdig - FIRST recently announced the CVSS 4.0 Public Preview with a target official publication date of Oct....

CVSS v4.0 Frequently Asked Questions - The Common Vulnerability Scoring System (CVSS) is an open framework for communicating the characteri...

Quantifying medical device cybersecurity risk with CVSS BTE - Nature - This study is based on the new CVSS standard, version 4.0, released on November 1, 2023. As of today...

CVSS Fragmentation | Michał Walkowski - Monthly snapshot of NVD CVSS coverage, intersections, and severity distributions across CVSS v2.0, v...

CVSS v4 adoption is low due to lack of incentives - LinkedIn - It's been 1.5 years since the initial release of FIRST CVSS v4 in November 2023, yet only 2.4% of CV...

NVD CVE Analysis Rate Report - At the time of this reports generation, NVD's 2025 daily average for analyzing new CVEs is 115.22. T...

2025 CVE Data Review - JerryGamblin.com - The average CVSS score for 2025 was 6.60, with a median of 6.50. This indicates a concentration of v...

Sonatype Intelligence Reveals CVE Program Leaves Majority of Vulnerabilities Unscored - Inconsistent and delayed open source vulnerability data results in 150,000 false negatives, leaving ...

CVSS Scores No Longer Enough: The Move to Context-Driven ... - Vulnerability scoring models such as CVSS 3.1 and CVSS 4.0 must evolve to include contextual informa...

An Empirical Study of Vulnerability Scoring Systems - Moonlight - This paper presents the first large-scale, outcome-linked empirical comparison of four prominent and...

An Empirical Study of Vulnerability Scoring Systems - Accurately assessing software vulnerabilities is essential for effective prioritization and remediati...

CVSS 4.0 keys-in on threat intelligence metrics and OT, ICS and IoT - ... CVSS 4.0 focuses on base metrics for operational technology (OT), industrial control systems (IC...

The New CVSS 4.0 for OT / ICS / IoT - Radiflow - The CVSS score is represented simply as a number from 0 – 10 that represents the severity of a secur...

La Directiva NIS2

Health and Technology (2025) 15:635–650

DORA vs NIS2: Key Differences, Overlaps, and Compliance Impact - DORA (Digital Operational Resilience Act) is an EU regulation that has applied directly in EU member...

DORA & NIS2 compliance: Strengthening cybersecurity in 2025 - The NIS2 directive and DORA regulations represent key advancements in the European Union's efforts t...

Enisa launches European vulnerability database - Computer Weekly - The EU's new vulnerability database is designed to offer a broader, more transparent source of infor...

How to Use Europe's New Vulnerability Database - The European Cybersecurity Agency (ENISA) officially launched the European Union Vulnerability Datab...

November/December 2025 Critical Updates - Cyber Resilience Act - For the last few years, the Cyber Resilience Act (CRA) has been a topic of high-level policy debate....

Vulnerability Exposure & Severity Trends in 2025 - Appsecure Security - Explore 2025 vulnerability exposure and severity trends across web, cloud, APIs, and infrastructure....

Cyber Resilience Act: Overview for affected companies - From 11 September 2026, manufacturers must report any actively exploited vulnerability they become a...

Cyber Resilience Act - Reporting obligations - As of 11 September 2026, manufacturers are required to report actively exploited vulnerabilities and...

[PDF] RECOMENDACIÓN ESQUEMA NACIONAL DE SEGURIDAD ...

Esquema Nacional de Seguridad: Guía completa de ... - Auditat - El Esquema Nacional de Seguridad (ENS) es clave. Descubre qué es, su obligatoriedad, categorías y la...

[PDF] PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD ... - El artículo 11 de Esquema Nacional de Seguridad (ENS) señala la obligación de que las entidades públ...

ENS y la gestión de incidentes de ciberseguridad - ESED - Una clasificación estructurada de nueve tipos de ciberincidentes, divididos en 36 subcategorías, que...

[PDF] Guía de Seguridad de las TIC CCN-STIC 817 ESQUEMA ... - AEC

Los incidentes críticos en España por ciberespionaje y cibercrimen ... - El Centro Criptológico Nacional del CNI ha gestionado más de 200.000 incidentes de ciberseguridad en...

La ciberseguridad y su relevancia en el Sector Público. ...

Respuesta 24x7 para Infraestructuras Críticas | INCIBE-CERT - Entre los servicios puestos en marcha en el marco de INCIBE-CERT destaca la respuesta ante incidente...

La Generalitat combatió 6.900 millones de ciberataques en 2024, 3.372 de ellos dañinos - La Generalitat combatió en 2024 un total de 6.900 millones de ciberataques enviados por piratas info...

[PDF] Informe Ciberseguridad 2025 | PTE Disruptive - En 2025, la ciberseguridad ha dejado de ser un asunto meramente tecnológico para convertirse en un p...

Marzo 2025: Ataque prorruso... - Siguen proliferando los ciberataques en España en 2025. El año ha empezado con noticias de ataques a...

Ataques informáticos en 2025: los 6 casos más graves en España - Los ataques informáticos crecen en 2025: Conoce los casos más graves en España y cómo proteger tus d...

Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...

España, bajo asedio digital: ciberataques golpean a gobiernos y ... - España ha vivido un primer semestre de 2025 marcado por una oleada de ciberataques que han puesto en...

La próxima gran crisis será en 2026: hospitales y ayuntamientos, en ... - 2025 ha servido para poner los pies en la tierra. Los ciberataques ya no van solo de robar informaci...

Stop Demonizing CVSS: Fix the Real Problem - Nucleus Security - Demonizing CVSS distracts from real issues in vulnerability management. Learn why operational challe...

Red Nacional de SOC (RNS) - Métricas e indicadores a utilizar en un SOC para mejorar su gestión; Listas blancas con ubicaciones ...

Spain Esquema Nacional de Seguridad (ENS) High-Level Security ... - It guides these agencies and companies in implementing effective controls for security in the cloud ...

SCIENCE AND TECHNOLOGY PUBLICATIONS - SCITEPRESS - Accurately predicting the Common Vulnerability Scoring System (CVSS) score from Common Vulnerability...

Nuovo rapporto di ricerca accettato per la presentazione a ICAART ... - The research report “JewelCVSS: A Domain-Tuned LLM for Automated Vulnerability Scoring”, carried out...

Assegnato a BV TECH il “Best Industrial Paper Award” della ... - ... 2026, the “Best Industrial Paper Award” was awarded to BV TECH for the research report “JewelCVS...

Assessing the Performance of LLMs for Automated Software ... - This study explores leveraging Large Language Models (LLMs) for automating vulnerability risk score ...

[PDF] Application of Large Language Models to Automatic Classification of ...

Knowledge-Driven Large Language Models for Automating CVSS ... - To automate vulnerability scoring, some researchers have used machine learning models to predict CVS...

The Government approves a strengthening of Spain's cybersecurity ... - The Council of Ministers today approved a set of actions in cybersecurity and cyberdefence that comp...

Despliegue y Operación del Centro de ... - España Digital - Asimismo, el Centro Criptológico Nacional (CCN-CERT) pone a disposición su capacidad de operación de...

Vulnerability Coordination under the Cyber Resilience Act - The paper examines and elaborates the CRA's new requirements for vulnerability coordination, includi...

A comprehensive review on the application of CVSS 4.0 and deep ... - This paper reviews the evolution of the Common Vulnerability Scoring System (CVSS), focusing on the ...

Comparing CVSS, EPSS, KEV, SSVC, LEV, and PXS - Picus Security - Compare CVSS, EPSS, KEV, SSVC, LEV & PXS. Understand each model's value, and why proof of exploitabi...

How CVSS v4.0 works: characterizing and scoring vulnerabilities - What's new in CVSS v4.0? · 1. Expanded metric groups · 2. Refined scoring and terminology · 3. Great...